

Cibersegurança e operações de segurança

Módulo completo: todas as aulas num só PDF · 15 h de estudo · 1 aula

Conteúdo programático

Objetivos do módulo

- ✓ Conhecer ameaças, defesas e resposta a incidentes

Temas

- Tríade CIA
- Firewalls, IDS, IPS, SIEM
- Backups 3-2-1
- Resposta a incidentes
- NIST CSF e ISO 27001

Aulas deste módulo

Resumo dos comandos Cisco do módulo	1
1 Operações de cibersegurança · 20 min · básico	2

Resumo dos comandos Cisco do módulo

As aulas deste módulo não têm comandos Cisco IOS.

Operações de cibersegurança

E4 — Cibersegurança e operações de segurança · 20 min de leitura · vídeo-aula 3 min · nível básico

Nesta aula vai aprender a

- ✓ Conhecer firewalls, IDS, IPS e SIEM
- ✓ Aplicar backups e resposta a incidentes
- ✓ Conhecer enquadramentos de segurança

Como estudar esta aula

1

Veja a vídeo-aula na app (3 min).

2

Leia este PDF com calma e sublinhe o que é importante.

3

Faça os exercícios da pág. 5.

4

Confira as soluções na pág. 8.

ANTES DESTA AULA

Esta aula continua a última aula do módulo anterior (E3): **E3 · Aula 1 de 1 — Analisar tráfego com o Wireshark**. Se ainda não a fez, comece por lá; se já a fez, releia os objetivos dela e confirme que os domina.

Índice

1. Ferramentas de defesa	3
2. Resposta a incidentes	3
3. Backups 3-2-1 e boas práticas	3
4. Simulador × Equipamento real	3
5. Termos técnicos	3
6. Exercícios para fazer	5
7. Quiz	6
8. Soluções	8
9. Referências bibliográficas	9

1. Ferramentas de defesa

Defesa	O que faz
Firewall stateless	Filtra cada pacote isolado (como uma ACL)
Firewall stateful	Lembra-se das ligações e só deixa voltar as respostas
NGFW	Identifica aplicações e utilizadores; inclui IPS
IDS	Deteta e alerta
IPS	Deteta e bloqueia
SIEM	Junta e correlaciona logs de toda a rede
EDR	Proteção avançada nos PCs e servidores

2. Resposta a incidentes

Fase	Ações
Preparação	Planos, contactos, ferramentas
Deteção e análise	Alertas, confirmar o incidente
Contenção	Isolar o equipamento afetado
Erradicação	Remover a causa
Recuperação	Repor serviços e dados
Lições aprendidas	Melhorar

3. Backups 3-2-1 e boas práticas

3 cópias dos dados, em **2** tipos de suporte, **1** fora do local (ou offline, contra ransomware). Junte palavras-passe fortes, **MFA**, atualizações e formação. Enquadramentos: **NIST CSF** (Identificar, Proteger, Detetar, Responder, Recuperar, Governar) e **ISO/IEC 27001**.

4. Simulador × Equipamento real

NO SIMULADOR No Packet Tracer pode configurar uma ASA 5506-X com zonas inside/outside e DMZ.	NO EQUIPAMENTO REAL - Teste os backups: um backup que nunca foi restaurado não é um backup. - Tenha os contactos de emergência fora dos sistemas que podem ser cifrados.
---	--

5. Termos técnicos

O que quer dizer cada palavra técnica que aparece na aula, em linguagem simples.

Firewall — Equipamento ou programa que controla que tráfego pode entrar e sair de uma rede, segundo regras. Exemplo: A firewall deixa entrar a porta 443 para o servidor web e bloqueia o resto.

IDS (Intrusion Detection System (sistema de deteção de intrusões)) — Sistema que vigia o tráfego e avisa quando vê algo suspeito, mas não o bloqueia. Exemplo: O IDS envia um alerta ao ver muitas tentativas de login falhadas.

IPS (Intrusion Prevention System (sistema de prevenção de intrusões)) — Sistema que vigia o tráfego e bloqueia automaticamente os ataques que reconhece. Exemplo: O IPS deita fora os

pacotes de um ataque conhecido antes de chegarem ao servidor.

Backup — Cópia de segurança dos dados, guardada noutro sítio, para recuperar se o original se perder. Exemplo: Copiar todas as noites a base de dados do hospital para um disco externo é fazer backup.

Pacote — Bloco de dados com endereços IP de origem e destino; é a unidade da camada de rede. Exemplo: Uma página web chega ao PC dividida em dezenas de pacotes.

ACL (Access Control List (lista de controlo de acesso)) — Lista de regras num router que permite ou bloqueia pacotes, conforme endereços, protocolos e portas. Exemplo: `access-list 10 deny 192.168.2.0 0.0.0.255` bloqueia a rede 192.168.2.0.

Firewall com estado (stateful firewall) — Firewall que se lembra das ligações abertas e deixa entrar automaticamente as respostas. Exemplo: O PC pede uma página e a resposta entra; um pedido vindo de fora sem ser pedido é bloqueado.

Aplicação — Programa feito para uma tarefa concreta do utilizador, que corre por cima do sistema operativo. Exemplo: O WhatsApp e o Excel são aplicações.

Utilizador — Pessoa que usa um computador ou serviço. Normalmente tem um nome de utilizador e uma palavra-passe. Exemplo: A enfermeira entra no sistema com o utilizador «ana.silva».

Syslog — Protocolo e sistema para enviar mensagens de registo (logs) dos equipamentos para um servidor central. Exemplo: Os switches enviam por Syslog (UDP 514) a mensagem «interface down».

Rede — Dois ou mais equipamentos ligados entre si para partilhar informação e recursos. Exemplo: Os computadores e a impressora de um escritório ligados ao mesmo switch formam uma rede.

Servidor — Computador ou programa que fornece um serviço a outros (clientes). Exemplo: Um servidor DHCP dá endereços IP aos PCs da rede.

Dados — Factos soltos, sem contexto, que o computador guarda e trata. Exemplo: «38,9» sozinho é um dado; «a doente tem 38,9 °C» já é informação.

Ransomware — Malware que cifra os ficheiros da vítima e pede resgate para os devolver. Exemplo: Um hospital sem backups fica sem acesso às fichas dos doentes até pagar.

Palavra-passe — Segredo que prova que o utilizador é quem diz ser. Exemplo: Uma boa palavra-passe tem pelo menos 12 caracteres, como «Cafe-Luanda-2025!».

Autenticação multifator (MFA — Multi-Factor Authentication) — Provar a identidade com mais de um tipo de prova: algo que sabe, que tem ou que é. Exemplo: Palavra-passe + código SMS no telemóvel.

Atualização de segurança (patch) — Correção publicada pelo fabricante para fechar uma vulnerabilidade. Exemplo: Instalar as atualizações do Windows todos os meses.

Packet Tracer (Cisco Packet Tracer) — Simulador gratuito da Cisco para montar e testar redes no computador, sem equipamentos reais. Exemplo: No Packet Tracer liga-se um router, dois switches e PCs e configura-se tudo pela CLI.

DMZ (Demilitarized Zone (zona desmilitarizada)) — Rede intermédia entre a Internet e a rede interna, onde ficam os servidores acessíveis de fora. Exemplo: O servidor web público fica na DMZ, separado dos PCs dos funcionários.

6. Exercícios para fazer

Os 10 exercícios obrigatórios desta aula. Responda à mão nas linhas; as soluções, com a resolução, estão no fim deste PDF. Na app pode fazer exercícios novos sem fim.

1. O que quer dizer a sigla **Atualização de segurança**?

- ☐ **A)** GB
- ☐ **B)** Interior Gateway Protocol
- ☐ **C)** patch
- ☐ **D)** cavalo de Troia

2. O que quer dizer a sigla **IPS**?

- ☐ **A)** OTDR (refletómetro) para localizar cortes
- ☐ **B)** Intrusion Prevention System (sistema de prevenção de intrusões)
- ☐ **C)** banner motd (message of the day)
- ☐ **D)** guest network

3. O que quer dizer a sigla **Autenticação multifator**?

- ☐ **A)** ACL padrão (números 1-99 e 1300-1999)
- ☐ **B)** Designated Router (router designado)
- ☐ **C)** MFA — Multi-Factor Authentication
- ☐ **D)** Server Message Block; também chamado CIFS

4. O que significa **Servidor**?

- ☐ **A)** Computador ou programa que fornece um serviço a outros (clientes).
- ☐ **B)** Mensagens ICMPv6: o PC envia Router Solicitation a pedir informação e o router responde com Router Advertisement (prefixo, gateway).
- ☐ **C)** Encaminhamento entre VLANs usando um router com uma só interface física ligada a um trunk, dividida em subinterfaces.
- ☐ **D)** Emulador de redes que corre imagens reais de equipamentos.

5. O que significa **IPS** (Intrusion Prevention System (sistema de prevenção de intrusões))?

- ☐ **A)** Protocolo para ler e-mails mantendo-os no servidor, sincronizados entre vários equipamentos.
- ☐ **B)** Sistema que vigia o tráfego e bloqueia automaticamente os ataques que reconhece.
- ☐ **C)** Comando que esconde (com cifra fraca) as palavras-passe que aparecem em texto na configuração.
- ☐ **D)** Passar de um access point para outro sem perder a ligação, ao andar pelo edifício.

6. O que significa **Dados**?

- ☐ **A)** Tempo de inatividade ao fim do qual a sessão da CLI se fecha sozinha.
- ☐ **B)** Forma de criar a parte de interface (64 bits) de um endereço IPv6 a partir do MAC: insere-se FFFE no meio e troca-se o 7.^o bit.
- ☐ **C)** Modelo em que os clientes pedem e um servidor central responde.
- ☐ **D)** Factos soltos, sem contexto, que o computador guarda e trata.

7. O que quer dizer a sigla Firewall com estado?

- ☐ **A)** rollover
- ☐ **B)** P2P (par a par)
- ☐ **C)** Remote Authentication Dial-In User Service
- ☐ **D)** stateful firewall

8. O que significa Atualização de segurança (patch)?

- ☐ **A)** Endereço IP único no mundo, encaminhável na Internet, atribuído pelo operador.
- ☐ **B)** Correção publicada pelo fabricante para fechar uma vulnerabilidade.
- ☐ **C)** Modelo de cloud em que se usa um programa pronto pela Internet.
- ☐ **D)** Programa livre que permite a um servidor Linux partilhar pastas e impressoras com PCs Windows, usando SMB.

9. O que significa Firewall?

- ☐ **A)** Encaminhamento entre VLANs usando um router com uma só interface física ligada a um trunk, dividida em subinterfaces.
- ☐ **B)** Equipamento ou programa que controla que tráfego pode entrar e sair de uma rede, segundo regras.
- ☐ **C)** Trama com menos de 64 bytes, normalmente resultado de uma colisão.
- ☐ **D)** Formato de texto para dados com etiquetas de abertura e fecho.

10. O que significa Ransomware?

- ☐ **A)** Regras que dizem quem pode ler ou alterar uma pasta quando ela é acedida pela rede.
- ☐ **B)** Software gravado dentro de um equipamento que o faz funcionar. Muda-se raramente, numa «atualização de firmware».
- ☐ **C)** Malware que cifra os ficheiros da vítima e pede resgate para os devolver.
- ☐ **D)** Protocolo para ler e-mails mantendo-os no servidor, sincronizados entre vários equipamentos.

7. Quiz

4 perguntas. Para concluir a aula na app precisa de 70% no quiz.

1. Diferença entre IDS e IPS?

- ☐ **A)** O IDS bloqueia, o IPS só alerta
- ☐ **B)** O IDS alerta, o IPS bloqueia
- ☐ **C)** São iguais
- ☐ **D)** Nenhum vê tráfego

2. O que diz a regra 3-2-1?

- ☐ **A)** 3 cópias, 2 suportes, 1 fora do local
- ☐ **B)** 3 firewalls, 2 routers, 1 switch
- ☐ **C)** 3 senhas por pessoa
- ☐ **D)** Nada

3. Primeira ação ao detetar um PC com ransomware?

- ☐ **A)** Isolar o PC da rede
- ☐ **B)** Pagar
- ☐ **C)** Reiniciar o servidor
- ☐ **D)** Apagar os logs

4. Uma firewall stateful lembra-se das ligações iniciadas.

- ☐ Verdadeiro ☐ Falso

Porquê? _____

8. Soluções

Exercícios

1. **Resposta:** C) patch

Atualização de segurança = patch. Correção publicada pelo fabricante para fechar uma vulnerabilidade.

2. **Resposta:** B) Intrusion Prevention System (sistema de prevenção de intrusões)

IPS = Intrusion Prevention System (sistema de prevenção de intrusões). Sistema que vigia o tráfego e bloqueia automaticamente os ataques que reconhece.

3. **Resposta:** C) MFA — Multi-Factor Authentication

Autenticação multifator = MFA — Multi-Factor Authentication. Provar a identidade com mais de um tipo de prova: algo que sabe, que tem ou que é.

4. **Resposta:** A) Computador ou programa que fornece um serviço a outros (clientes).

Servidor: Computador ou programa que fornece um serviço a outros (clientes).

Exemplo: Um servidor DHCP dá endereços IP aos PCs da rede.

5. **Resposta:** B) Sistema que vigia o tráfego e bloqueia automaticamente os ataques que reconhece.

IPS: Sistema que vigia o tráfego e bloqueia automaticamente os ataques que reconhece.

Exemplo: O IPS deita fora os pacotes de um ataque conhecido antes de chegarem ao servidor.

6. **Resposta:** D) Factos soltos, sem contexto, que o computador guarda e trata.

Dados: Factos soltos, sem contexto, que o computador guarda e trata.

Exemplo: «38,9» sozinho é um dado; «a doente tem 38,9 °C» já é informação.

7. **Resposta:** D) stateful firewall

Firewall com estado = stateful firewall. Firewall que se lembra das ligações abertas e deixa entrar automaticamente as respostas.

8. **Resposta:** B) Correção publicada pelo fabricante para fechar uma vulnerabilidade.

Atualização de segurança: Correção publicada pelo fabricante para fechar uma vulnerabilidade.

Exemplo: Instalar as atualizações do Windows todos os meses.

9. **Resposta:** B) Equipamento ou programa que controla que tráfego pode entrar e sair de uma rede, segundo regras.

Firewall: Equipamento ou programa que controla que tráfego pode entrar e sair de uma rede, segundo regras.

Exemplo: A firewall deixa entrar a porta 443 para o servidor web e bloqueia o resto.

10. **Resposta:** C) Malware que cifra os ficheiros da vítima e pede resgate para os devolver.

Ransomware: Malware que cifra os ficheiros da vítima e pede resgate para os devolver.

Exemplo: Um hospital sem backups fica sem acesso às fichas dos doentes até pagar.

Quiz — chave de respostas

1. **Resposta:** B) O IDS alerta, o IPS bloqueia

IPS está no caminho.

2. **Resposta:** A) 3 cópias, 2 suportes, 1 fora do local

Backups.

3. **Resposta:** A) Isolar o PC da rede

Contenção.

4. **Resposta:** Verdadeiro

E deixa voltar as respostas.

9. Referências bibliográficas

1. NIST. SP 800-63B: Digital Identity Guidelines – Authentication and Lifecycle Management. Gaithersburg: NIST, 2017.
2. ODOM, Wendell. CCNA 200-301 Official Cert Guide, Volume 2. 2. ed. Hoboken: Cisco Press, 2024.